

# VirtuEx 시스템 감사 보고서 (2차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 2차 감사 작성일: 2026-03-01 수정일: 2026-03-02 작성: 시스템 감사 팀

## 1. 개요

2차 감사는 1차 감사 이후 추가된 기능 및 기존 코드 전반에 대해 보안, 데이터 무결성, 성능, 프론트엔드 품질, 인프라를 종합적으로 점검합니다. 백엔드 8개 서비스, 프론트엔드, 인프라 구성 전체를 대상으로 수행되었습니다.

### 1.1 감사 범위

| 영역             | 점검 항목 수               | 발견 이슈 |
|----------------|-----------------------|-------|
| 백엔드 보안 및 코드 품질 | 8개 서비스                | 25건   |
| 프론트엔드 UX 및 품질  | 컴포넌트/훅/페이지            | 28건   |
| 인프라 및 설정       | Docker/Prisma/환경변수/빌드 | 32건   |
| 합계             |                       | 85건   |

## 2. 보안 감사

### 2.1 발견된 보안 이슈

| # | 항목                          | 위험도 | 상태      |
|---|-----------------------------|-----|---------|
| 1 | Docker Compose DB 비밀번호 하드코딩 | 상   | ✅ 수정 완료 |
| 2 | WebSocket CORS 검증 미적용       | 중   | ✅ 수정 완료 |
| 3 | 내부 서비스 Rate Limiting 부재     | 중   | ⏸️ 스킵   |
| 4 | 이메일 민감 데이터 로그 노출            | 중   | ✅ 수정 완료 |
| 5 | 채팅 참여자 권한 검증 부족             | 중   | ✅ 수정 완료 |
| 6 | Next.js 보안 헤더 미적용           | 중   | ✅ 수정 완료 |
| 7 | Docker 이미지 버전 미고정           | 중   | ✅ 수정 완료 |

### 2.2 1차 대비 개선 현황

- `.env.example` 민감값 플레이스홀더 교체 ✅
- SMS 코드 프로덕션 마스킹 ✅
- 하드코딩 보안 상수 ConfigService 이관 ✅
- Docker 자격증명 환경변수 패턴 적용 ✅

## 3. 에러 핸들링

### 3.1 빈 catch 블록 (Silent Failures)

| #  | 항목              | 위험도 | 상태               |
|----|-----------------|-----|------------------|
| 8  | 가격 알림 예러 무시     | 중   | ✅ logger.warn 추가 |
| 9  | 주문 프록시 알림 실패 무시 | 중   | ✅ logger.warn 추가 |
| 10 | 로그인 로그 생성 실패 무시 | 하   | ✅ logger.warn 추가 |
| 11 | 시세 데이터 발행 실패 무시 | 중   | ✅ logger.warn 추가 |

## 4. 데이터 무결성

### 4.1 타입 안전성

| #  | 항목                    | 위험도 | 파일                                         | 상태                     |
|----|-----------------------|-----|--------------------------------------------|------------------------|
| 12 | Balance 서비스 any 타입 사용 | 중   | balance.service.ts:196,262,324             | ✅ 수정 완료 — string 타입 적용 |
| 13 | 프론트엔드 any 타입 다수       | 중   | LoginSmsModal.tsx:15,<br>useOrders.ts:104  | ✅ 수정 완료                |
| 14 | i18n 키 강제 타입 캐스팅      | 중   | orders/page.tsx:640,<br>Ailnsights.tsx:139 | ✅ 수정 완료 — 누락 키 추가      |

### 4.2 입력 검증 부재

| #  | 항목                    | 위험도 | 파일                          | 상태                             |
|----|-----------------------|-----|-----------------------------|--------------------------------|
| 15 | Portfolio 쿼리 파라미터 미검증 | 중   | portfolio.controller.ts:119 | ✅ 수정 완료 — bounds check (1-100) |
| 16 | 내부 API symbol 미검증     | 중   | internal.controller.ts      | ✅ 수정 완료 — 정규식 검증 추가            |
| 17 | 채팅 헤더 디코딩 미검증         | 중   | chat.controller.ts:47,87    | ✅ 수정 완료 — try-catch + 100자 제한  |

### 4.3 경쟁 조건

| #  | 항목                  | 위험도 | 파일                                  | 상태                          |
|----|---------------------|-----|-------------------------------------|-----------------------------|
| 18 | 가격 알림 트리거 경쟁 조건     | 중   | price-subscriber.service.ts:140-144 | ✅ 수정 완료 — DB 실패 시 캐시 복원     |
| 19 | 뉴스 스크래핑 동시 실행 방지 없음 | 중   | news.service.ts:147-150             | ✅ 수정 완료 — isScraping 플래그 추가 |

### 4.4 Prisma 스키마

| #  | 항목                         | 위험도 | 파일                            | 상태                                      |
|----|----------------------------|-----|-------------------------------|-----------------------------------------|
| 20 | Order Engine @updatedAt 누락 | 중   | order-engine/schema.prisma:28 | ✅ 수정 완료                                 |
| 21 | Market Data @updatedAt 누락  | 중   | market-data/schema.prisma 전체  | ⏮ 스킵 — 이벤트성 데이터로 updatedAt 불필요 (의도적 설계) |
| 22 | PriceAlert 복합 인덱스 누락       | 하   | user-auth/schema.prisma       | ✅ 수정 완료                                 |

## 5. 인프라 감사

### 5.1 Docker 구성

| #  | 항목                              | 위험도 | 상태                                             |
|----|---------------------------------|-----|------------------------------------------------|
| 23 | 컨테이너 로깅 설정 미적용                  | 중   | ✅ 수정 완료 — json-file + max-size 10m, max-file 3 |
| 24 | CPU 제한 미설정                      | 중   | ✅ 수정 완료 — postgres 1.0, redis 0.5, kafka 1.5   |
| 25 | pgAdmin/Redis Commander 헬스체크 없음 | 하   | ✅ 수정 완료 — wget 기반 헬스체크 추가                      |

### 5.2 환경 변수

| #  | 항목                        | 위험도 | 상태                                |
|----|---------------------------|-----|-----------------------------------|
| 26 | 서비스별 DATABASE_URL 미기재     | 상   | ✅ 수정 완료 — .env.example에 5개 URL 추가 |
| 27 | 서비스 시작 시 환경변수 검증 부재       | 중   | ✅ 수정 완료 — 6개 서비스 main.ts에 검증 추가   |
| 28 | backup-db.sh 비밀번호 하드코딩 풀백 | 중   | ✅ 수정 완료 — :? 구문으로 교체              |

### 5.3 빌드 설정

| #  | 항목                                        | 위험도 | 상태                       |
|----|-------------------------------------------|-----|--------------------------|
| 29 | turbo.json 환경변수 의존성 불완전                   | 중   | ✅ 수정 완료 — .env 추가        |
| 30 | NestJS 버전 불일치 (chat/notification/ai: v10) | 중   | ✅ 수정 완료 — v11 통일         |
| 31 | Prisma 버전 불일치 (chat: ^6.0.0)              | 중   | ⏮ 확인 완료 — 이미 ^6.0.0으로 통일 |

### 5.4 Prometheus

| # | 항목 | 위험도 | 상태 |
|---|----|-----|----|
|---|----|-----|----|

|    |                               |   |                       |
|----|-------------------------------|---|-----------------------|
| 32 | host.docker.internal macOS 전용 | 중 | ✅ 수정 완료 — 주석 추가       |
| 33 | scrape_timeout 미설정            | 하 | ✅ 수정 완료 — 10초 타임아웃 추가 |

## 6. 프론트엔드 감사

### 6.1 성능

| #  | 항목                               | 위험도 | 상태                          |
|----|----------------------------------|-----|-----------------------------|
| 34 | AssetListItem React.memo 미적용     | 상   | ✅ 수정 완료                     |
| 35 | WebSocket 구독 해제 누락               | 상   | ✅ 수정 완료 — unsubscribe 추가    |
| 36 | AssetList 필터 핸들러 useCallback 미적용 | 중   | ✅ 수정 완료                     |
| 37 | AI Insights 지연 로딩 미적용            | 중   | ✅ 수정 완료 — dynamic import 적용 |

### 6.2 접근성

| #  | 항목                             | 위험도 | 상태                      |
|----|--------------------------------|-----|-------------------------|
| 38 | OrderSheet 닫기 버튼 터치 영역 부족      | 상   | ✅ 수정 완료 — p-3 (48px)    |
| 39 | BottomNav 일부 아이콘 aria-label 누락 | 중   | ✅ 수정 완료                 |
| 40 | 아바타/심볼 아이콘 대체 텍스트 없음           | 중   | ✅ 수정 완료 — aria-label 추가 |

### 6.3 상태 관리

| #  | 항목                    | 위험도 | 상태                            |
|----|-----------------------|-----|-------------------------------|
| 41 | 주문 수정 중복 클릭 방지 없음     | 중   | ✅ 수정 완료 — isPending 체크        |
| 42 | SMS 인증 중복 제출 방지 없음    | 중   | ✅ 수정 완료 — isSubmitting ref 추가 |
| 43 | AI Insights 에러 상태 미표시 | 중   | ✅ 수정 완료 — 에러 UI 추가            |

### 6.4 UX

| #  | 항목                       | 위험도 | 상태                          |
|----|--------------------------|-----|-----------------------------|
| 44 | 채팅방 나가기 확인 모달 없음         | 상   | ✅ 수정 완료 — window.confirm 추가 |
| 45 | 프로필 수정 버튼 스타일 불일치        | 중   | ✅ 수정 완료 — 통일 높이 적용          |
| 46 | ConnectionGuard 메시지 하드코딩 | 중   | ✅ 수정 완료 — useTranslation 적용 |

## 7. 코드 품질

### 7.1 발견 항목

| # | 항목 | 위험도 | 상태 |
|---|----|-----|----|
|---|----|-----|----|

|    |                                  |   |                                      |
|----|----------------------------------|---|--------------------------------------|
| 47 | 에러 메시지 한영 혼용                     | 하 | 🔗 인지 — 현재 디버깅에 큰 영향 없음, 향후 개선 예정     |
| 48 | 내부 API Swagger 문서 부재             | 하 | ✅ 수정 완료 — @ApiOperation 데코레이터 추가     |
| 49 | BigInt prototype 전역 변경           | 하 | ✅ 수정 완료 — NestJS Interceptor로 이관     |
| 50 | strictPropertyInitialization 비활성 | 하 | ⏭️ 스킵 — 전역 tsconfig 변경 영향 범위가 넓어 미적용 |

## 8. 종합 평가

### 8.1 수정 결과

| 상태              | 건수 |
|-----------------|----|
| ✅ 수정 완료         | 45 |
| ⏭️ 스킵 (의도적/불필요) | 4  |
| 🔗 인지 (향후 개선)    | 1  |
| 합계              | 50 |

### 8.2 스킵 항목 사유

| #  | 항목                           | 사유                                           |
|----|------------------------------|----------------------------------------------|
| 3  | 내부 Rate Limiting             | InternalAuthGuard로 충분, 과도한 제한은 서비스 간 통신에 부작용 |
| 21 | Market Data @updatedAt       | 이벤트성 데이터로 updatedAt 불필요 (의도적 설계)             |
| 31 | Chat Prisma 버전               | 이미 ^6.0.0으로 통일 완료                            |
| 50 | strictPropertyInitialization | 전역 tsconfig 변경 영향 범위가 넓어 미적용                 |

본 보고서는 VirtuEx 시스템의 2차 감사 결과이며, 2026-03-02 수정 결과를 반영합니다.